

# 白象APT组织已将CVE 2017-11882纳入攻击武器库

腾讯电脑管家

2018-01-10 共299970人围观，发现 9 个不明物体

安全报告

## 特别说明：

本报告中出现的 IOC 由于其相关信息的敏感性和特殊性，所以在本报告中暂不对外披露，在报告中呈现的相关内容（文字、图片等）均通过打码隐藏处理。若您对本报告的内容感兴趣，需要了解报告相关细节或相关 IOC，可与腾讯反病毒实验室联系。

## 1. 概述

近期，腾讯反病毒实验室捕获一例针对某国大使馆的钓鱼文档，该钓鱼文档利用CVE-2017-11882漏洞传播远控木马。经过分析，该样本属于白象组织的攻击样本。

白象APT组织，又称Hangover，DroppingElephant等，该组织来自南亚某国家，长期针对中国、巴基斯坦及其他部分南亚国家从事网络间谍活动。组织由国外安全厂商Norman在2013年5月16日首次曝光，在最近的几年时间里，该APT组织一直活跃并不断改进攻击武器，其攻击能力相比从前也有了大幅提高。从以往公布的针对白象APT组织的报告来看，该APT组织主要通过钓鱼邮件和仿冒网站传播木马，而钓鱼文档通常为军事、政治相关的OFFICE文档，已知的该组织使用过的漏洞包括：CVE-2012-0158、CVE-2013-3906、CVE-2014-6352、CVE-2014-4114、CVE-2017-0199，而这次腾讯反病毒实验室发现CVE-2017-11882漏洞也已经该APT组织被加入到攻击漏洞武器库，对此，腾讯反病毒实验室预测该组织在此后的攻击中，会更加青睐于“较新”的CVE-2017-11882漏洞，同时这也是第一份公开的该组织对CVE 2017-11882漏洞的利用。基于这样考虑，腾讯反病毒实验室决定发布此篇分析报告，揭露该组织最新的漏洞利用攻击技术细节，以补齐安全厂商对该APT组织的拼图，更完整的还原该APT组织。

腾讯反病毒实验室捕获钓鱼文档的时间为2017年12月底，钓鱼文档内容为某国外交部门针对大使馆工作人员就访问某国的行程通知内容，从代码层来看，文档为CVE 2017-11882漏洞利用文档。在未打该漏洞补丁的电脑上打开该文档加载远控木马并最终导致该主机被黑客控制。通过对攻击过程的分析，怀疑黑客还可能会仿冒某国际关系理事会的官方网站，以伺机对相关利益国家进行渗透活动。

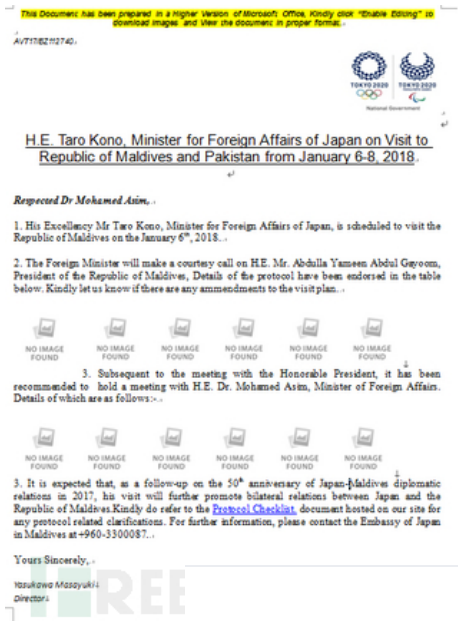
## 2. 攻击过程分析

### 2.1 钓鱼文档

文档内容上看来自某国外交部门，文档的主要内容是与该国驻外使馆进行访问的计划内容。

从文档的元数据看，文档的创建时间为2017-12-27，与文档内容中的行程日期(2018-01-06)相隔很一周，表明钓鱼文档是对该部门专门定制。一旦用户下载并打开该恶意文档，该文档使用CVE-2017-11882漏洞，利用该漏洞无需交互，用户感知弱的特点，来实现文档打开自动运行恶意代码的效果。

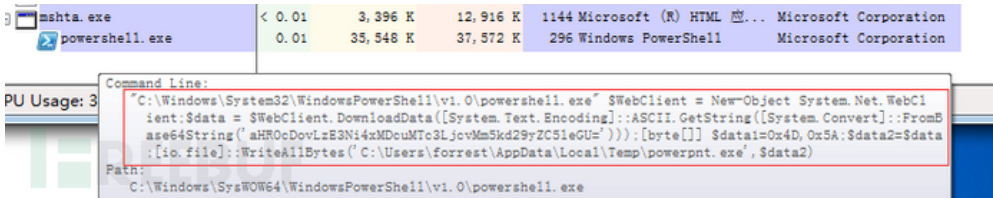
文档截图如下：







从processxp中看到的进程信息如下：



2.3 powerpnt.exe

powershell下载到本地的powerpnt.exe文件，在功能上看是一个loader程序。

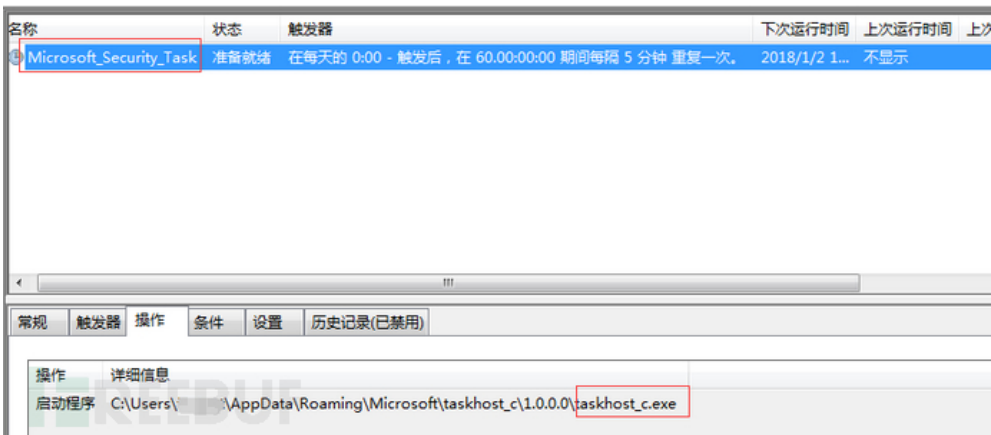
该loader程序的编译时间为2017年11月29日，虽然该编译时间可以被篡改，但此处仍有参考价值。该exe的基本信息如下：

|      |                                       |
|------|---------------------------------------|
| MD5  | C9*****DC                             |
| 大小   | 1048064(字节)                           |
| 时间戳  | 0x5A1DB0BB (Wed Nov 29 02:53:47 2017) |
| 编译语言 | Microsoft Visual C# / Basic .NET      |

powerpnt.exe的主要功能为：释放最终的XRAT后门程序，并将后门程序加入到计划任务中。

添加到计划任务中的后门程序，每五分钟启动一次。

添加的计划任务内容：

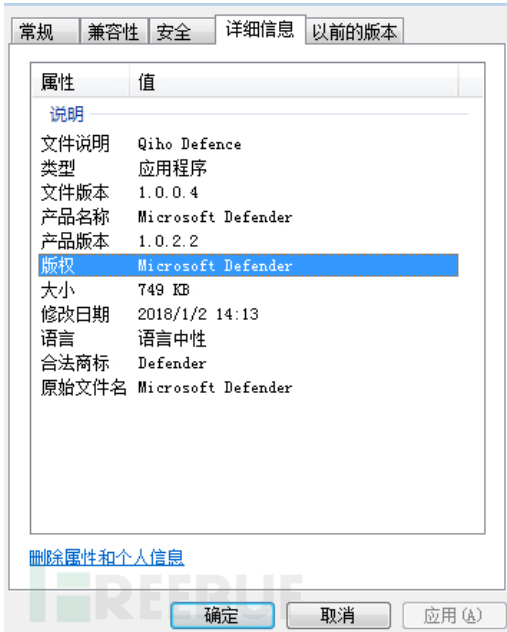


2.4 XRAT远控木马

XRAT远控木马具有远程进程管理、远程文  
压缩与加密。

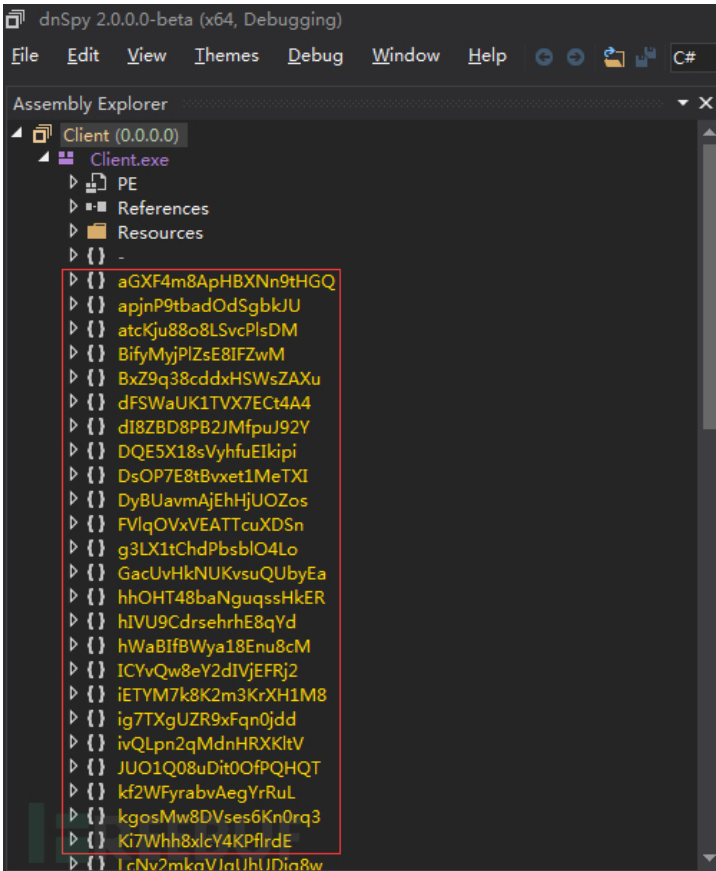
|      |                                       |
|------|---------------------------------------|
| 大小   | 766976字节                              |
| 时间戳  | 0x5A1D44A1 (Tue Nov 28 19:12:33 2017) |
| 编译语言 | Microsoft Visual C# / Basic .NET      |

XRAT远控木马伪装成word图标，从样本的版本信息中的产品名称为MicrosoftDefender，其他的版本信息如下图：



在每五分钟的时间周期内，后门程序会被加载，该RAT程序属于xRat家族的远控木马，该木马的代码已经开源，通过分析，RAT最终与d\*\*\*\*\*n.cor 23558端口进行木马协议通信。

该rat程序的模板名为client，其代码已被高强度混淆，如下图。

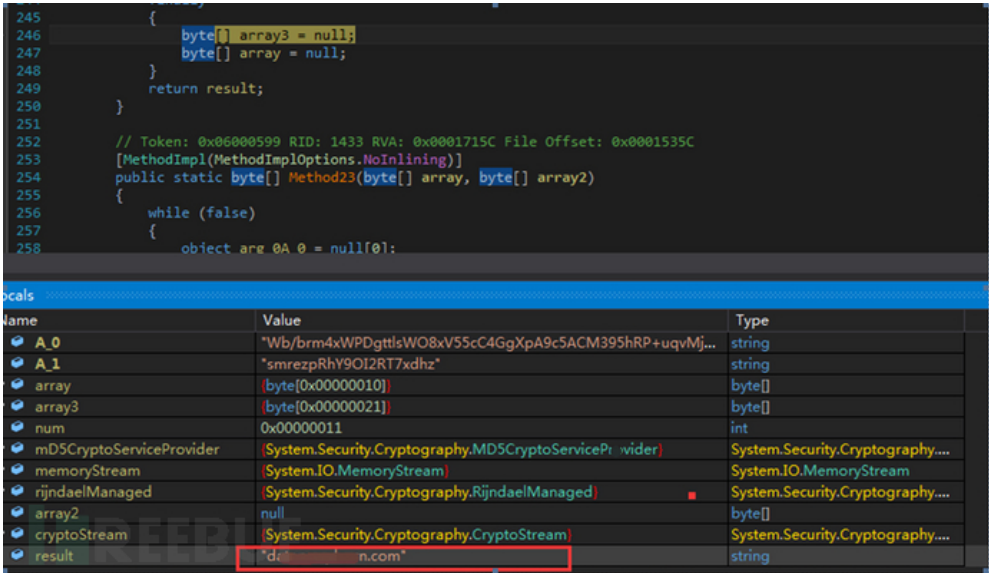


关于该xrat的配置信息指黑客在生成该木马



|             |                                 |        |
|-------------|---------------------------------|--------|
| VERSION     | 2.0.0.0 RELEASE3                | 木马版本号  |
| HOST        | datapeople-cn.com               | 木马上线地址 |
| PASSWORD    | g00gle@209.58.185.36            | 上线验证密码 |
| SUBFOLDER   | Brix                            | 木马释放目录 |
| INSTALLNAME | brix.exe                        | 木马安装名称 |
| MUTEX       | SlzJwsc5iW5uZHOeROkhowkC9mZ5eqJ | 互斥体    |
| STARTUPKEY  | Brix                            | 启动项    |

下图为通过AES算法解密出上线地址的代码片段：



3. CC扩展:

能过上面的分析，漏洞利用文档使用的CC地址如下：

<http://1xx.xxx.xxx.7/calc2.doc>

<http://1xx.xxx.xxx.7/2ndword.exe>

通过对1xx.xxx.xxx.7的passive DNS查询，可以看到该IP地址在2017年12月底解析到的域名atlanticcouncil.org中

| Resolve             | First      | Last       | Source                     | Tags       |
|---------------------|------------|------------|----------------------------|------------|
| atlanticcouncil.org | 2017-12-26 | 2018-01-02 | pingly, riskiq, virustotal | Registered |
| datapeople-cn.com   | 2016-08-10 | 2016-08-16 | riskiq                     | Registered |
| datapeople-cn.com   | 2016-01-05 | 2016-01-05 | riskiq                     | Registered |

针对axxxxxxl.org域名，它与某国际关系理事会官方网站相比，只是少了一个字母c，因此我们怀疑该域名是该APT组织用来仿冒某国际关系理事会'方网站的。该国际关系理事会主旨在为国际政治，商业和知识领袖提供对话论坛，鼓励北美和欧洲之间的合作。

通过腾讯反病毒实验室后台大数据对样本进行关联分析，我们发掘出该APT组织在2017年11月至2018年1月新开发的诸多木马样本，根据样本的CC地址查找出来一些可疑域名。如其中的一个域名（tecchweb.com）注册于2017年11月28日，怀疑该域名会用来仿冒TechWeb 资讯服务的网站。

4. 总结

这次事件起始于腾讯反病毒实验室对白象APT组织的持续跟踪，捕获到精心构造的钓鱼文档，通过对文档CC地址的扩展，关联出仿冒某国际关系理事会的域名地址，从CC域名上来看，攻击者十分注重基础设施的隐藏，在这次事件中的CC地址没有重叠使用情况，这对于攻击的追踪与溯源都带来了极大的困难，但基于腾讯反病毒实验室的安全大数据，从样本特征出发，从单一样本关联出更多的既往样本，进而定位出该样本属于白象APT组织。从这可以看出，所有的网络犯罪事件，仅从单一样本进行追踪是低效的，基于大数据的攻击发掘与追踪势在必行。

除此之外，这也是第一次发现白象APT组织使用CC地址进行钓鱼攻击，这也说明该组织在攻击手段上已经能够进行有效的伪装，检测系统已经能够对此类攻击进行有效检测。

上一篇：[天才遇上一笨亿万网站头施网络诈骗的通报预警及情况分析](#)

下一篇：[“噩梦公式”二代 | 2018年微软修复的首个Office 0day漏洞（CVE-2018-0802）分析](#)

这些评论亮了



abctest

<http://176.107.177.7/2ndword.exe>

回复

亮了(7)

已有 9 条评论

- 1111 2018-01-10

天天白象////天天xxxx草。。。

亮了
- 别BB 2018-01-10

@ 1111 你牛逼你分析一个，分析不出来就好好看别人的成果学习进步

亮了
- mobi看这里 2018-01-10

漏点了

亮了 (
- McR 2018-01-10

这么抠门，写份报告都打码！

亮了
- [Wncy\\_2017](#) (1级) 2018-01-10

1.码没打全

2.tecchweb.com的注册时间不对。

亮了 (
- 河蟹 2018-01-10

打码的报告 真的，，，， 让人，，，， 无语

亮了 (
- [jimoyong](#) (5级) 2018-01-10

直接说印度不就好了= =

亮了
- abctest 2018-01-11

<http://176.107.177.7/2ndword.exe>

亮了 (
- [msr00t](#) (1级) 2018-03-08

请问：样本可以在哪儿找到呀

亮了 (

选择文件

未选择任何文件



评论人昵称

邮箱

必须 (保密)

请输入邮箱地址

表情

插图

提交评论(Ctrl+Enter)

取消

☒

有人回复时邮件通知我



腾讯电脑管家

腾讯电脑管家官方账号

142

文章数

1

评论数

最近文章

- 酷玩游戏盒子伪造知名公司数字签名，传播Steam盗号木马

2018.12.13
- 利用AapcheStruts高危漏洞入侵的双平台挖矿木马

2018.12.07
- 主页保安成锁主页病毒母体 随激活工具传播

2018.12.05

浏览更多

相关阅读

- [CVE-2017-11882新动态：利用AutoL...](#)
- [一个CVE-2017-11882漏洞新变异样...](#)
- [又出新玩法？微软公式编辑器系列漏...](#)
- [白象APT组织已将CVE 2017-11882纳...](#)
- [利用了Office公式编辑器特殊处理逻辑...](#)

特别推荐



活动预告

|                                                                         |                                                                           |                                                                   |  |
|-------------------------------------------------------------------------|---------------------------------------------------------------------------|-------------------------------------------------------------------|--|
| <div>11月</div> <div>FreeBuf精品公开课·双11学习狂欢节 给努力的你打打气</div> <div>已结束</div> | <div>10月</div> <div><u>【16课时-连载中】挖掘CVE不是梦（系列课程2）</u></div> <div>已结束</div> | <div>10月</div> <div><u>【首节课仅需1元】挖掘CVE不是梦</u></div> <div>已结束</div> |  |
|-------------------------------------------------------------------------|---------------------------------------------------------------------------|-------------------------------------------------------------------|--|



Copyright © 2018 WWW.FREEBUF.COM All Rights Reserved [沪ICP备13033796号](#)

